

Windows Defender Evasion Attempt

L1Notes :	Minutes before the alert, I saw brute force attempts towards the system on IP 89.187.177.73. However, I could not determine whether these attempts were successful or not. Therefore, I could not understand whether the relevant command was attacker or admin activity.
Hostname :	Elenora
IPAddress :	172.16.17.126
EDRAVAction :	Not Detected
ProcessName :	RUNDLL32.EXE
TriggerReason :	The combination of rundll32 and vbscript is a technique often used for malicious activity. This command can be intended to bypass Defender's detection and protection mechanisms, which can cause security systems to generate an alert.

De acordo com o L1 houve uma tentativa de bruteforce

< Hide Fields	Event
INTERESTING FIELDS	2024-09-12 01:07:02 OS 89.187.177.73 41589 → 172.16.17.126 3389 EventID: 4624 An account was successfully logged on. Username: letsdefend, Source IP: 89.187.177.73, Login Type: 10(RemoteInteractive)
type	2024-09-12 01:06:59 OS 89.187.177.73 64332 → 172.16.17.126 3389 EventID: 4625 An account failed to log on. Username: LetsDefend, Source IP: 89.187.177.73, Error Code: 0xc000006a (user name is correct but the password is wrong)
source_address	2024-09-12 01:06:38 OS 89.187.177.73 56953 → 172.16.17.126 3389 EventID: 4625 An account failed to log on. Username: LetsDefend, Source IP: 89.187.177.73, Error Code: 0xc000006a (user name is correct but the password is wrong)
source_port	2024-09-12 01:06:21 OS 89.187.177.73 15893 → 172.16.17.126 3389 EventID: 4625 An account failed to log on. Username: LetsDefend, Source IP: 89.187.177.73, Error Code: 0xc000006a (user name is correct but the password is wrong)
destination_address	2024-09-12 01:06:19 OS 89.187.177.73 43665 → 172.16.17.126 3389 EventID: 4625 An account failed to log on. Username: LetsDefend, Source IP: 89.187.177.73, Error Code: 0xc000006a (user name is correct but the password is wrong)
destination_port	2024-09-12 01:06:13 OS 89.187.177.73 21371 → 172.16.17.126 3389 EventID: 4625 An account failed to log on. Username: LetsDefend, Source IP: 89.187.177.73, Error Code: 0xc000006a (user name is correct but the password is wrong)
raw_log	2024-09-12 01:06:10 OS 89.187.177.73 18591 → 172.16.17.126 3389 EventID: 4625 An account failed to log on. Username: LetsDefend, Source IP: 89.187.177.73, Error Code: 0xc000006a (user name is correct but the password is wrong)

Checando nos logs é possível identificar realmente um comportamento de bruteforce com vários EventID: 4625 seguidos de um EventID: 4624 indicando sucesso ao logar na conta pela porta 3389 (RDP)

Processes	Network Action	Terminal History 12	Browser History	Results: 10
EVENT TIME	COMMAND LINE			
Sep 12 2024 07:07:40	whoami /all			
Sep 12 2024 07:07:36	whoami			
Sep 12 2024 07:09:35	rundll32 vbscript:"\\.\mshtml\..\mshtml\RunHTMLApplication *String(CreateObject("Wscript.Shell").Run("calc.exe"),0)			
Sep 12 2024 07:09:22	rundll32 vbscript:"\\.\mshtml\..\mshtml\RunHTMLApplication *String(CreateObject("Wscript.Shell").Run("calc.exe"),0)			
Sep 12 2024 07:09:03	Get-NetFirewallProfile			
Sep 12 2024 07:08:56	Get-MpPreference Select-Object -Property DisableRealTimeMonitoring			
Sep 12 2024 07:08:49	Get-Service -Name WinDefend			
Sep 12 2024 07:08:40	Get-Service Where-Object { \$_.Status -eq 'Running' }			
Sep 12 2024 07:08:35	net share			
Sep 12 2024 07:08:19	Get-NetTCPConnection			
Sep 12 2024 07:08:03	Get-WmiObject -Class Win32_UserAccount			
Sep 12 2024 07:07:51	net user			

A sequência de comandos do terminal é suspeita, tem uma boa cara de tentativa de reconhecimento, como status do defender, conexões abertas, usuários, whoami, serviços com status “running”, seguida de uma tentativa de executar a calculadora com o rundll32.exe

Isso é um abuso de componentes legítimos/LOLBin e técnica de evasão, ele tenta executar o mshtml com o interpretador do vbscript, usando a função RunHTMLApplication, dentro dela ele evoca o objeto Wscript.Shell que permite interação com o SO e usa .Run para tentar executar a calculadora, a técnica de evasão foi o “directory transversal” que ele fez na hora de selecionar o mshtml, usando varios ..\teste\..\123\..\tantofaz\..\mshtml ele tenta bypassar as defesas que já conhecem essa assinatura

Sep 12 2024 07:09:29	3252	MsMpEng.exe	services.exe	"C:\ProgramData\Microsoft\Windows Defende...
Sep 12 2024 07:09:27	5004	sihost.exe	svchost.exe	sihost.exe
Sep 12 2024 07:09:25	5016	cmd.exe	explorer.exe	"C:\Windows\system32\cmd.exe"
Sep 12 2024 07:09:22	5252	explorer.exe	userinit.exe	C:\Windows\Explorer.EXE
Sep 12 2024 07:09:01	640	svchost.exe	services.exe	C:\Windows\system32\svchost.exe -k DcomLa...

Na árvore de processos não foi possível encontrar a calculadora, provavelmente o comando não deu certo

Nesse caso, para confirmar, os logs do defender com EventID 1116 e 1117 devem mostrar essa tentativa, o evento 1116 indica que um malware foi detectado e 1117 que uma medida foi tomada

The screenshot displays the Windows Defender log interface. On the left, a tree view shows various system components, with 'Windows Defender' expanded to show 'Operational' logs. The main pane shows a list of events. Event 1116 is highlighted, showing a warning that Microsoft Defender Antivirus has detected malware or other potentially unwanted software. The details pane for Event 1116 shows the following information:

- Name: Trojan:Win32/Powesere.G
- ID: 2147725444
- Severity: Severe
- Category: Trojan
- Path: CmdLine: C:\Windows\System32\rundll32.exe vbscript:..\..\mshtml\..\mshtml\..\..\mshtml,RunHTMLApplication +String(CreateObject(Wscript.Shell).Run (calc.exe),0)
- Detection Origin: Unknown
- Detection Type: Concrete

Below this, Event 1117 is highlighted, showing an information event. The details pane for Event 1117 shows the following information:

- Path: CmdLine: C:\Windows\System32\rundll32.exe vbscript:..\..\mshtml\..\mshtml\..\..\mshtml,RunHTMLApplication +String(CreateObject(Wscript.Shell).Run (calc.exe),0)
- Detection Origin: Unknown
- Detection Type: Concrete
- Detection Source: System
- User: NT AUTHORITY\SYSTEM
- Process Name: Unknown
- Action: Remove
- Action Status: No additional actions required
- Error Code: 0x00000000
- Error description: The operation completed successfully.
- Security intelligence Version: AV: 1.405.860.0, AS: 1.405.860.0, NIS: 1.405.860.0

O Microsoft Defender detectou a atividade e realizou uma ação de remediação/bloqueio.

Check an IP Address, Domain Name, Subnet, ASN, or IP List
e.g. 2804:7f0:b1c3:b530:e0b1:8fcc:4e1e:1fec, microsoft.com, 5.188.10.0/24, AS15169, or Multi NEW

89.187.177.73 CHECK

89.187.177.73 was found in our database!

This IP was reported 149 times. Confidence of Abuse is 36%.

36%

ISP	DataCamp s.r.o.
Usage Type	Data Center/Web Hosting/Transit
ASN	AS60068
Hostname(s)	unn-89-187-177-73.cdn77.com
Domain Name	datacamp.co.uk
Country	United States of America
City	New York City, New York

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 89.187.177.73 WHOIS 89.187.177.73

Find Unique Website Themes by Designers around the world. Explore Themes >

Amazing Themes made by Creators just like you.

ADS VIA CARBON

SPONSOR

Netlify One gateway for every AI model

O IP que realizou o ataque de bruteforce foi considerado malicioso, existem outros eventos registrados sobre esse IP com tentativas de bruteforce, Web attack, Bruteforce-BOT

T1110 – Brute Force

T1021 - Remote Services

T1218 - System Binary Proxy Execution

T1059 - Command and Scripting Interpreter

Horário:

Sep 12 2024 07:09:22

IoCs:

Endereços IP:

89.187.177.73

Comando:

```
rundll32 vbscript:"..\mshtml\..\mshtml\..\mshtml,RunHTMLApplication  
"+String(CreateObject("Wscript.Shell").Run("calc.exe"),0)
```

Análise:

O alerta foi disparado por um comando malicioso conhecido, o N1 detectou um bruteforce naquele host antes do ataque, foi confirmado que o bruteforce foi bem sucedido na máquina de IP 172.16.17.126, não parece ter indícios de que outras máquinas foram afetadas também, ao analisar o histórico da shell e a árvore de processos foi possível identificar comportamento suspeito de reconhecimento, junto do comando que disparou o alerta tentando executar a calculadora, o windows defender barrou o comando.

O IP 89.187.177.73 que realizou o bruteforce foi dado como malicioso pelo AbuseIPDB

Recomendações:

- Não deixar portas de acesso remoto como RDP expostas para a internet a não ser que seja realmente necessário
- Fortalecer a política de senhas